🖥️ Lab 1 – FinCore Bank

Linux Sunucu Güvenlik Denetimi Deneyimi

Senaryo

Bir bilgi sistemleri denetçisi olarak FinCore Bank'ın internet yüzüne açık kritik Linux sunucularından birinin güvenlik denetimini gerçekleştirmek üzere görevlendirildiniz.
Denetim planlama görüşmeleri sırasında sistem sahipleri ve teknik ekip ile yaptığınız görüşmelerde aşağıdaki bilgiler paylaşılmıştır:

- Sunucu AWS ortamında çalışmaktadır.
- Sunucu internet üzerinden erişilebilmektedir.
- Sunucuda kritik veya hassas veri tutulmamaktadır.
- Ancak müşteri ve sistem verileri bu sunucu üzerinden geçebilmektedir.
- Gereksiz kullanıcı hesapları bulunmamaktadır.
- Tüm kullanıcı hesapları iş ihtiyacı doğrultusunda oluşturulmuştur.
- Parola politikaları güçlüdür.
- SSH erişimi sektör standartlarına uygun şekilde yapılandırılmıştır.
- Sistemde hassas veri veya gizli bilgi içeren dosyalar bulunmamaktadır.
- İşletim sistemi düzenli olarak güncellenmektedir.
- Gereksiz servisler devre dışı bırakılmıştır.
- Güvenlik yapılandırmaları eksiksiz uygulanmıştır.

Kısacası sistem sahiplerinin ifadesine göre sunucuda herhangi bir güvenlik zafiyeti veya yapılandırma hatası bulunmamaktadır.
Ancak bir denetçi olarak yalnızca beyanlara güvenmek yerine kanıt toplamanız ve teknik doğrulama gerçekleştirmeniz beklenmektedir.
Bu amaçla denetlenen ekipten yalnızca okuma yetkisine sahip (read-only) bir kullanıcı hesabı talep ettiniz. Ekip size gerekli erişim bilgilerini sağlayarak inceleme yapmanıza izin verdi.
Göreviniz; bu internet yüzüne açık Linux sunucusunu teknik olarak incelemek, riskleri belirlemek, bulguları kanıtlarıyla desteklemek ve profesyonel bir denetim raporu hazırlamaktır.

Erişim Bilgileri

SSH istemcisi kullanarak sunucuya bağlanabilirsiniz.
Öncelikle özel anahtar dosyanızın yetkilerini düzenleyin:

```
chmod 400 "cyberlab.pem"
```

Daha sonra aşağıdaki komut ile bağlanın:

```
ssh -i "cyberlab.pem" ec2-user@[redacted]
```

Sunucu DNS Adresi:
[redacted]
🔑 Erişim anahtarını support@siberkobi.co adresinden talep edebilirsiniz.
Daha önce aldıysanız bu adımı atlayabilirsiniz.

Beklentiler

Denetim sırasında aşağıdaki başlıkları risk bakış açısıyla değerlendirmeniz beklenmektedir:

- Kullanıcı ve grup yönetimi
- Yetkilendirme kontrolleri
- SSH güvenliği
- Parola politikaları
- Hassas veri yönetimi
- Dosya ve dizin izinleri
- Log yönetimi
- Patch yönetimi
- Çalışan servisler
- Sistem hardening kontrolleri
- İnternet yüzüne açık sistem riskleri
- İşletim sistemi güvenliği
- AWS ortamına ilişkin gözlemler

Amaç komut ezberlemek değil, bir denetçi gibi düşünerek riskleri tespit etmek ve kanıtlarla destekleyebilmektir.

Teslimat

Çalışma sonunda yalnızca bu sunucuya özel kısa bir denetim raporu hazırlayın. Raporda aşağıdaki bölümler bulunmalıdır:

1. Yönetici Özeti
2. Denetim Kapsamı
3. Yapılan Testler
4. Tespit Edilen Bulgular
5. Risk Değerlendirmesi
6. Öneriler

Hazırladığınız raporu:
📧 support@siberkobi.co
veya
👤 Volkan Güler
ile paylaşabilirsiniz.

Önemli Not

Bu laboratuvar çalışması eğitim amaçlı hazırlanmıştır.
Lab ortamında yer alan kullanıcılar, dosyalar, veriler, yapılandırmalar ve senaryolar tamamen eğitim amacıyla oluşturulmuştur. Çalışma sırasında karşılaşacağınız hiçbir bilgi, kurum, kullanıcı veya veri gerçek bir kişi, kurum ya da üretim ortamını temsil etmemektedir.
Amaç; katılımcıların gerçek hayatta karşılaşabilecekleri Linux güvenlik denetimlerini kontrollü bir ortamda deneyimlemeleri ve risk odaklı denetim yaklaşımını uygulamalı olarak öğrenmeleridir.

****

Linux Security Audit – Denetçi Rehberi

1. İşletim Sistemi Bilgileri

```
cat /etc/os-release
uname -a
hostnamectl
uptime
```

Amaç:
- İşletim sistemi sürümünü belirlemek
- Kernel versiyonunu görmek
- Desteklenen sürüm olup olmadığını değerlendirmek

2. Kullanıcı Hesapları
Tüm kullanıcılar:

```
cat /etc/passwd
```

Sadece normal kullanıcılar:

```
awk -F: '$3 >= 1000 {print $1}' /etc/passwd
```

Kullanıcı detayları:

```
id test
id admin
id developer
id tempconsultant
id backupsvc
```

Parola yaşlandırması:

```
sudo chage -l test
sudo chage -l admin
sudo chage -l developer
```

Amaç:
- Shared account bulmak
- Eski çalışan hesaplarını bulmak
- Servis hesaplarını tespit etmek

3. Yetkili Kullanıcılar
Sudo yetkileri:

```
sudo -l -U test
sudo -l -U developer
```

Sudoers dosyaları:

```
cat /etc/sudoers
ls -l /etc/sudoers.d/
```

İçerik:

```
cat /etc/sudoers.d/*
```

Amaç:
- NOPASSWD kullanımı
- Aşırı yetkilendirme

4. SSH Güvenliği

SSH ayarları:

```
cat /etc/ssh/sshd_config
```

Özellikle ara:

```
grep PermitRootLogin /etc/ssh/sshd_config
grep PasswordAuthentication /etc/ssh/sshd_config
grep ClientAlive /etc/ssh/sshd_config
```

Amaç:
- Root login
- Password authentication
- Session timeout

5. Servisler

Çalışan servisler:

```
systemctl list-units --type=service --state=running
```

FTP:

```
systemctl status vsftpd
```

Web sunucusu:

```
systemctl status httpd
```

Audit:

```
systemctl status auditd
```

Firewall:

```
systemctl status firewalld
```

Amaç:
- Gereksiz servisler
- FTP kullanımı
- Audit eksikliği
- Firewall eksikliği

6. Ağ ve Açık Portlar
Portlar:

```
ss -tulpn
```

Alternatif:

```
netstat -tulpn
```

Amaç:
- Beklenmeyen servisler
- Gereksiz dinleyen portlar

7. Patch Yönetimi
Güncellemeler:

```
sudo dnf check-update
```

Yüklü kernel:

```
rpm -qa | grep kernel
```

Amaç:
- Eksik yamalar
- Eski kernel

8. Dosya İzinleri
World Writable Dosyalar:

```
find / -type f -perm -002 2>/dev/null
```

World Writable Dizinler:

```
find / -type d -perm -002 2>/dev/null
```

Amaç:
- 777 dosyalar
- 777 klasörler

9. Hassas Veri Avı
Anahtar kelimeler:

```
find / -type f 2>/dev/null
```

Dizinleri incele:

```
ls -la /finans
ls -la /ik
ls -la /backup
ls -la /uygulama
ls -la /yedekler
ls -la /shared
```

Dosya içerikleri:

```
cat /finans/maaslar_2026.csv
cat /ik/personel_bilgileri.txt
cat /uygulama/veritabani.conf
cat /yedekler/aws_anahtarlari.txt
cat /backup/musteriler.sql
```

Amaç:
- Hassas veri
- Maaş bilgileri
- Kimlik bilgileri
- Veritabanı şifreleri
- AWS erişim anahtarları

10. Dosya Sahiplikleri

```
ls -l /finans
ls -l /ik
ls -l /backup
ls -l /uygulama
```

Amaç:
- Yetkisiz erişim
- Yanlış izinler

11. Log Yönetimi

Loglar:

```
ls -lah /var/log
```

Audit:

```
systemctl status auditd
```

Logrotate:

```
systemctl status logrotate.timer
```

Amaç:

- Audit eksikliği
- Log yönetimi eksikliği

12. Cron Görevleri

Kullanıcı cronları:

```
crontab -l
```

Sistem cronları:

```
ls -la /etc/cron*
```

Amaç:

- Yetkisiz işler
- Şüpheli görevler

13. Ayrıcalıklı Dosyalar

SUID:

```
find / -perm -4000 -type f 2>/dev/null
```

SGID:

```
find / -perm -2000 -type f 2>/dev/null
```

Amaç:

- Yetki yükseltme riskleri